Análise de segurança | fiware/orion

Trivy - TESTE04 | Debian 13.4 | amd64 | 19/10/2026

Resumo: 832 ocorrências (820 HIGH e 12 CRITICAL), correspondentes a 744 CVEs distintos. Há versão de correção registrada em 714 ocorrências; 118 não têm *FixedVersion*. A presença do pacote não comprova exploração no Orion.

Vulnerabilidades relevantes, impacto e correção

1. GnuTLS (CRITICAL) - libgnutls30t64: CVE-2026-33845 permite indisponibilidade e possível vazamento de dados por fragmentos DTLS malformados; CVE-2026-42010 permite contornar autenticação em servidores RSA-PSK. Atualizar **3.8.9-3+deb13u2 para 3.8.9-3+deb13u4**. O impacto depende do uso desses recursos.

2. OpenSSL (HIGH) - libssl3t64, openssl, openssl-provider-legacy: CVE-2026-45447 pode causar falha, corrupção de memória ou execução de código ao verificar PKCS#7/S/MIME; CVE-2026-84782 pode expor memória ou causar indisponibilidade em DTLS; CVE-2026-14456 esgota memória em servidores QUIC. Atualizar **3.5.5-1~deb13u2 para 3.5.7-1~deb13u3**, contemplando as correções listadas.

3. curl (HIGH) - curl, libcurl4t64: CVE-2026-6276 e CVE-2026-8927 podem vazar cookies e cabeçalhos de autenticação de proxy ao reutilizar handles; CVE-2026-92392 causa uso de memória liberada em uploads HTTP/2. Atualizar **8.14.1-2+deb13u2 para 8.14.1-2+deb13u7**. CVE-2026-12064 e CVE-2026-8458 não têm correção indicada: usar URLs SFTP/SCP com esquema explícito e evitar reutilizar conexões Negotiate entre serviços distintos.

4. Processamento de entradas (HIGH): CVE-2026-86145 e CVE-2026-103111 em **libpcre2-8-0** permitem escrita fora dos limites com expressões regulares controladas pelo atacante; atualizar para **10.46-1~deb13u3**. CVE-2026-11822 e CVE-2026-11824 em **libsqlite3-0** podem executar código ao consultar bases FTS5 maliciosas; atualizar para **3.46.1-7+deb13u2**. CVE-2026-55200 em **libssh2-1t64** permite corrupção de memória e execução remota de código; o JSON indica correção em **1.11.1-1+deb13u1**.

5. Perl (CRITICAL) - perl-base: CVE-2026-42496 permite acesso a arquivos fora do diretório de extração por links maliciosos; CVE-2026-13221 pode invalidar filtros baseados em expressões regulares muito grandes. Atualizar **5.40.1-6 para 5.40.1-6+deb13u1** e impedir extração de arquivos não confiáveis. CVE-2026-8376 descreve overflow em builds de 32 bits; a imagem é amd64, portanto sua aplicabilidade precisa ser confirmada.

6. Privilégios locais (HIGH) - mount, util-linux e pacotes relacionados: CVE-2026-53612, CVE-2026-53613 e CVE-2026-53614 podem elevar privilégios sob configurações específicas de SUID/fstab. Aplicar a correção Debian indicada, **2.41.5-0+deb13u1**, preservando o epoch de cada pacote. CVE-2026-76642 e CVE-2026-78410 não têm versão corrigida informada. Restringir montagens por usuários, remover SUID desnecessário e evitar execução privilegiada.

7. Kernel - linux-libc-dev: concentra 695 ocorrências, incluindo as críticas CVE-2026-43011, CVE-2026-43037, CVE-2026-43185, CVE-2026-53215, CVE-2026-63825, CVE-2026-90037 e CVE-2026-93221. As descrições incluem corrupção de memória e falhas de concorrência. O registro desse pacote de desenvolvimento **não comprova exposição do kernel em execução**; validar separadamente o host e os subsistemas usados. Remover o pacote da imagem final se dispensável.

Ação prática prioritária

Reconstruir a imagem com os pacotes corrigidos, testar o Orion e executar nova varredura antes de substituir os contêineres. Manter o usuário **nobody** já configurado e limitar privilégios e recursos expostos. Para achados sem *FixedVersion*, restringir o recurso afetado e acompanhar a correção; campo vazio não prova inexistência de patch. As versões acima são as informadas no JSON, sem validação externa.

Fonte exclusiva: TRIVY_FIWARE_ORION_HIGH_CRITICAL_TESTE04.json, encontrado na pasta analise-4. O caminho com subpastas informado na solicitação não existe. Seleção priorizada; não é uma reprodução integral dos achados.